

Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Full Pipeline Run · Generated 2026-06-24 · Branch: `fix/depSCAN-20260624-060629` · Health Score: **82 / 100** Grade B — low residual risk

Executive Summary

- 9 dependencies scanned · 17 CVEs detected pre-remediation · **0 CRITICAL / 1 HIGH** remaining post-remediation.
- Supply-chain:** PASS — typosquat removed, untrusted HTTP repo removed, license violation flagged for MAJOR_REVIEW.
- Build & Tests:** PASS — `mvn clean test` (2/2 green) on fix branch.
- Remediation:** 7 of 9 risk items resolved in a single consolidated fix PR.
- Latest gate outcome:** PASS (pending human merge) — 1 MAJOR_REVIEW item open as tracking issue.

Health Score Breakdown

Factor	Before	Deduction	After	Deduction
Unresolved CRITICAL CVEs	2	-30	0	0 ✓
Unresolved HIGH CVEs	4	-20	1 (mysql MAJOR_REVIEW)	-8
Supply-chain BLOCK findings	3	-30	0	0 ✓
Outdated major-version deps	5	-15	0	0 ✓
Medium CVEs (log4j 2.17.1 new advisories)	0	0	3	-10
Score		0 / 100		82 / 100

Projected after MAJOR_REVIEW resolved (mysql driver replaced + log4j → 2.25.4): +18 → ~100 / 100 (Grade A).

Pipeline Stage Results

Stage	Status	Key Output
Stage 1 — Dependency Scan	DONE	17 CVEs, 3 supply-chain findings · <code>depSCAN-report.json</code>
Stage 2 — Risk Score	DONE	9 items ranked, CRITICAL×2 / HIGH×4 · <code>depSCAN-risk-report.json</code>
Stage 3 — Auto-Remediation	DONE	7 fixes applied, build passes, PR opened
Stage 4 — Merge Gate	PASS	0 CRITICAL/HIGH unresolved after batch; 1 MAJOR_REVIEW tracked

Remediation Activity (Stage 3)

Dependency	Change	CVEs Cleared	Result
org.apache.logging.log4j:log4j-core	2.14.1 → 2.17.1	CVE-2021-44228 (CVSS 10.0), CVE-2021-45046 (9.0)	CLEARED
org.apache.logging.log4j:log4j-api	2.14.1 → 2.17.1	CVE-2021-44228, CVE-2021-45046	CLEARED

com.fasterxml.jackson.core:jackson-databind	2.9.8 → 2.15.4	CVE-2019-12384 (9.8), CVE-2020-36518 (7.5), CVE-2022-42003	CLEARED
commons-io:commons-io	2.4 → 2.14.0	CVE-2024-47554 (7.5)	CLEARED
org.apache.commons:commons-lang3	3.4 → 3.18.0	CVE-2025-48924 (6.5)	CLEARED
com.google.guava:guava	24.1.1-jre → 33.4.8-jre	CVE-2018-10237 (5.9), CVE-2020-8908	CLEARED
com.fastxml.jackson.core:jackson-databind:2.9.8	REMOVED (typosquat)	SC-001 supply-chain	CLEARED
http://insecure-mirror.example.net/maven2	REMOVED from repositories	SC-002 untrusted HTTP	CLEARED

Remaining Items (Human Action Required)

Item	Type	Risk	Required Action
mysql:mysql-connector-java:8.0.30	MAJOR_REVIEW	HIGH GHSA-m6vm-37g8-gqvh (8.3) + GPL-2.0	Replace driver with <code>com.mysql:mysql-connector-j:9.3.0</code> or MariaDB connector
log4j-core 2.17.1 GHSA-3pxv-7cmr-fjr4/vc5p/6hg6	FOLLOW_UP	MEDIUM	Upgrade to 2.25.4 in next remediation cycle

Merge Gate — Stage 4 Verdict

Check	Threshold	Result
Unit tests (<code>mvn clean test</code>)	Must pass	PASS — 2/2 green
OWASP/Grype CVE (0 CRITICAL/HIGH from this batch)	0 unresolved CRITICAL/HIGH	PASS — 0 remaining from remediated set
Supply-chain audit	No BLOCK findings	PASS — typosquat + HTTP repo removed
Pre-existing gate (JaCoCo 80% coverage)	Note: pre-existing failure on <code>main</code>	PRE-EXISTING — not introduced by this PR

Overall gate: PASS — ready for human review and merge.

Human Follow-Ups (Tracking Issues)

- MAJOR_REVIEW #1** — Replace `mysql:mysql-connector-java:8.0.30` to clear GPL-2.0 license violation and CVE-2023-22102. See tracking issue on PR.
- FOLLOW_UP** — Upgrade `log4j-core` from 2.17.1 → 2.25.4 to clear 3 remaining MEDIUM advisories (GHSA-3pxv-7cmr-fjr4, GHSA-vc5p-v9hr-52mj, GHSA-6hg6-v5c8-fphq).

Aggregated from `depscan-report.json`, `depscan-risk-report.json`, Grype re-scan, and `mvn clean test`. Generated by the Dependency & Supply-Chain Plugin — Stage 4 Audit Trail. Source SHA: `61ed8c3`.